

# **Индивидуальный проект**

**4 Этап. Использование nikto**

Панина Жанна Валерьевна

# Содержание

|          |                                           |           |
|----------|-------------------------------------------|-----------|
| <b>1</b> | <b>Цель работы</b>                        | <b>5</b>  |
| <b>2</b> | <b>Задание</b>                            | <b>6</b>  |
| <b>3</b> | <b>Теоретическое введение</b>             | <b>7</b>  |
| <b>4</b> | <b>Выполнение работы</b>                  | <b>9</b>  |
| 4.1      | Анализ результатов сканирования . . . . . | 12        |
| <b>5</b> | <b>Выводы</b>                             | <b>15</b> |

## Список иллюстраций

|     |                                                            |    |
|-----|------------------------------------------------------------|----|
| 4.1 | Запуск mysql и apache2 . . . . .                           | 9  |
| 4.2 | DVWA - выбор уровня безопасности . . . . .                 | 9  |
| 4.3 | Сканирование через ввод адреса хоста и порта . . . . .     | 10 |
| 4.4 | Сканирование через ввод URL-адреса . . . . .               | 10 |
| 4.5 | Выбор самого высокого уровня безопасности . . . . .        | 11 |
| 4.6 | Сканирование после изменения уровня безопасности . . . . . | 11 |

## **Список таблиц**

# 1 Цель работы

Научиться тестированию веб-приложений с помощью сканера nikto

## 2 Задание

Просканировать веб-приложение, используя nikto

## 3 Теоретическое введение

*nikto* — базовый сканер безопасности веб-сервера. Он сканирует и обнаруживает уязвимости в веб-приложениях, обычно вызванные неправильной конфигурацией на самом сервере, файлами, установленными по умолчанию, и небезопасными файлами, а также устаревшими серверными приложениями. Поскольку *nikto* построен исключительно на LibWhisker2, он сразу после установки поддерживает кросс-платформенное развертывание, SSL (криптографический протокол, который подразумевает более безопасную связь), методы аутентификации хоста (NTLM/Basic), прокси и несколько методов уклонения от идентификаторов. Он также поддерживает перечисление поддоменов, проверку безопасности приложений (XSS, SQL-инъекции и т. д.) и способен с помощью атаки паролей на основе словаря угадывать учетные данные авторизации.

Для запуска сканера *nikto* введите в командную строку терминала команду: `# nikto`

По умолчанию, как ранее было показано в других приложениях, при обычном запуске команды отображаются различные доступные параметры. Для сканирования цели введите `nikto -h <[адрес]> -p <[порт]>`, где — домен или IP-адрес целевого сайта, а — порт, на котором запущен сервис

Сканер *nikto* позволяет идентифицировать уязвимости веб-приложений, такие как раскрытие информации, инъекция (XSS/Script/HTML), удаленный поиск файлов (на уровне сервера), выполнение команд и идентификация программного обеспечения. В дополнение к показанному ранее основному сканированию *nikto* позволяет испытателю на проникновение настроить сканирование конкретной

цели. Рассмотрим параметры, которые следует использовать при сканировании.

- Указав переключатель командной строки -T с отдельными номерами тестов, можно настроить тестирование конкретных типов.
- Используя при тестировании параметр -t, вы можете установить значение тайм-аута для каждого ответа.
- Параметр -D V управляет выводом на экран.
- Параметры -o и -F отвечают за выбор формата отчета сканирования.

Существуют и другие параметры, такие как -mutate (угадывать поддомены, файлы, каталоги и имена пользователей), -evasion (обходить фильтр идентификаторов) и -Single (для одиночного тестового режима), которые можно использовать для углубленной оценки цели [**parasram**].

## 4 Выполнение работы

Запускаю mysql и apache2 (рис. 4.1).

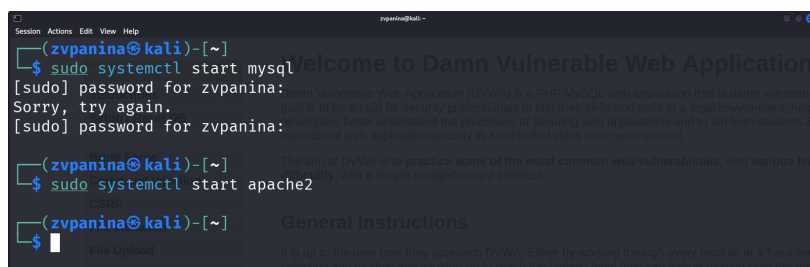


Рисунок 4.1: Запуск mysql и apache2

Ввожу в адресной строке браузера адрес DVWA и перехожу в режим выбора уровня безопасности, сначала поставлю минимальный - Low (рис. 4.2).

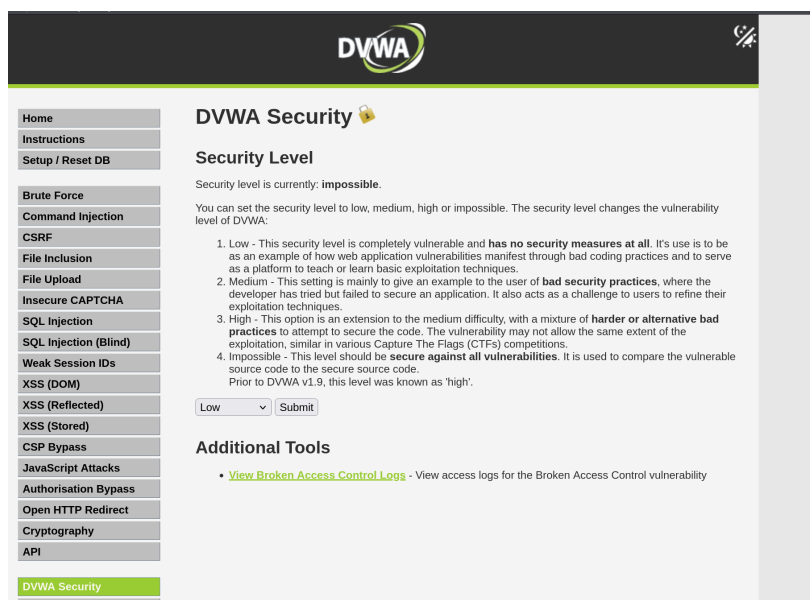


Рисунок 4.2: DVWA - выбор уровня безопасности

Запускаю nikto и проверяю веб-приложение, введя сначала адрес хоста и порта (рис. 4.3).

```
(zypolina@kali) [-]
$ nikto
--
(zypolina@kali) [-]
$ nikto -h 127.0.0.1 -p 80
Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Start Time: 2026-05-01 13:29:07 (GMT-4)

+ Server: Apache/2.4.65 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-c all' to force check all possible dirs)
+ /: Server may leak inodes via IFlags, header found with file /, inode: 29cf, size: 6450312aa0ba0, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-15354
+ OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS
+ /etc/passwd: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSD-08-561
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.
+ /assets/mobile/css/meta.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.
+ /login.cgi?cli=aa20aa27cat30/etc/passwd: Some D-Link router remote command execution.
+ /shellcat/etc/passwd: A backdoor was identified.
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host
+ End Time: 2026-05-01 13:29:21 (GMT-4) (14 seconds)

+ 1 host(s) tested

*****
Portions of the server's headers (Apache/2.4.65) are not in
the Nikto 2.5.0 database or are newer than the known string. Would you like
to submit this information (www server specific data*) to CIRT.net
for a Nikto update (or you may email to sullo@cirt.net) (y/n)? n
```

Рисунок 4.3: Сканирование через ввод адреса хоста и порта

Теперь пробую просканировать, введя полный URL-адрес (рис. 4.4). Результаты незначительно отличаются.

```
(zypolina@kali) [-]
$ nikto -h http://127.0.0.1/DVWA/
Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Start Time: 2026-05-01 13:30:29 (GMT-4)

+ Server: Apache/2.4.65 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (use '-c all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS
+ /DVWA//etc/passwd: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/database/: Database directory found.
+ /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ /DVWA/.git/index: Git index file may contain directory listing information.
+ /DVWA/.git/HEAD: Git HEAD file found. Full repo details may be present.
+ /DVWA/.git/config: Git config file found. Infos about repo details may be present.
+ /DVWA/.gitignore: .gitignore file found. It is possible to grasp the directory structure.
+ /DVWA/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.
+ /DVWA/assets/mobile/css/meta.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.
+ /DVWA/login.cgi?cli=aa20aa27cat30/etc/passwd: Some D-Link router remote command execution.
+ /DVWA/shellcat/etc/passwd: A backdoor was identified.
+ /DVWA/.dockerignore: .dockerignore file found. It may be possible to grasp the directory structure and learn more about the site.
+ 8074 requests: 0 error(s) and 26 item(s) reported on remote host
```

Рисунок 4.4: Сканирование через ввод URL-адреса

Попробую проделать теперь то же самое, изменив уровень безопасности на impossible (рис. 4.5).

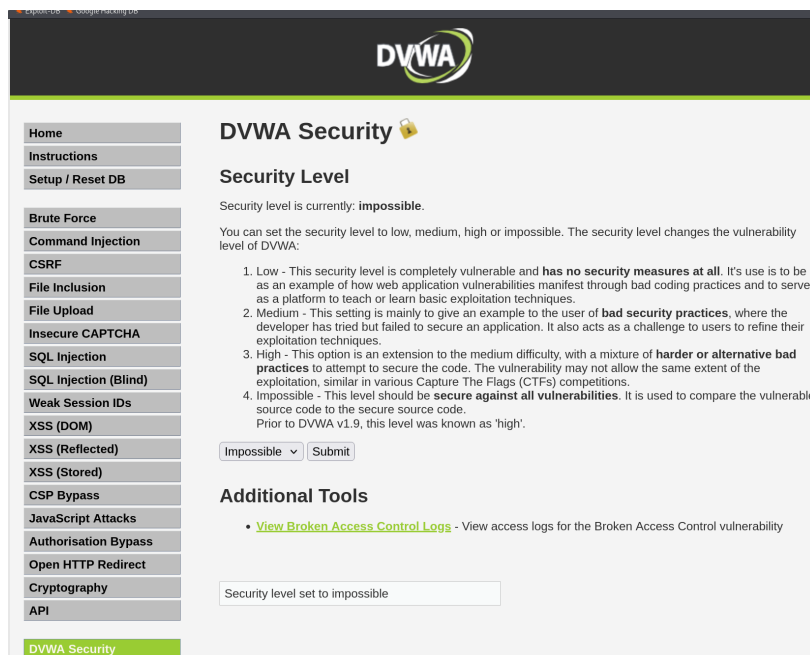


Рисунок 4.5: Выбор самого высокого уровня безопасности

Повторив предыдущую команду, я не заметила изменений в выводе информации (рис. 4.6).



Рисунок 4.6: Сканирование после изменения уровня безопасности

## 4.1 Анализ результатов сканирования

Кроме адреса хоста и порта веб-приложения, nikto выводит информацию о различных уязвимостях приложения:

Сервер: Apache/2.4.58 (Debian) + /DVWA/: Заголовок X-Frame-Options, защищающий от перехвата кликов, отсутствует. Смотрите: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>

- /DVWA/: Заголовок X-Content-Type-Options не задан. Это может позволить пользовательскому агенту отображать содержимое сайта способом, отличным от MIME-типа. Смотрите: <https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/>
- Корневая страница /DVWA перенаправляет на: login.php
- Каталоги CGI не найдены (используйте „-C all“, чтобы принудительно проверить все возможные каталоги)
- ОПЦИИ: Разрешенные HTTP-методы: GET, POST, OPTIONS, HEAD .
- /DVWA///etc/hosts: Установка сервера позволяет считывать любой системный файл, добавляя дополнительный «/» к URL-адресу.
- /DVWA/config/: Найдена индексация каталога.
- /DVWA/config/: Информация о конфигурации может быть доступна удаленно.
- /DVWA/tests/: Найдена индексация каталога.
- /DVWA/tests/: Это может быть интересно.
- /DVWA/database/: Найдена индексация каталога.
- /DVWA/база данных/: Найден каталог базы данных.
- /DVWA/документы/: Найдена индексация каталога.

- /DVWA/login.php: Найдена страница входа администратора/раздел.
- /DVWA/.git/index: Индексный файл Git может содержать информацию о списке каталогов.
- /DVWA/.git/HEAD: Найден файл Git HEAD. Может содержаться полная информация о репозитории.
- /DVWA/.git/config: Найден конфигурационный файл Git. Может содержаться информация о деталях репозитория.
- /DVWA/.gitignore: найден файл .gitignore. Можно разобраться в структуре каталогов.
- /DVWA/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: Обнаружен файловый менеджер с бэкдором на PHP.
- /DVWA/wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: Обнаружен файловый менеджер с бэкдором на PHP.
- /DVWA/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: Найден файловый менеджер с бэкдором на PHP.
- /DVWA/wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: Найден файловый менеджер с бэкдором на PHP.
- /DVWA/wp-включает в себя/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: Найден файловый менеджер бэкдора PHP.
- /DVWA/wordpress/wp-включает в себя/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: Найден файловый менеджер бэкдора на PHP.
- /DVWA/assets/mobirise/css/meta.php?filesrc=: Найден файловый менеджер бэкдора на PHP.

- /DVWA/login.cgi?cli=aa%20aa%27cat%20/etc/hosts: Удаленное выполнение какой-либо команды маршрутизатором D-Link.
- /DVWA/shell?cat+ /etc/hosts: Обнаружен черный ход.
- /DVWA/.dockerignore: найден файл .dockerignore. Возможно, удастся разобраться в структуре каталогов и узнать больше о сайте.

Бэкдор, тайный вход (от англ. back door — «чёрный ход», «лазейка», буквально «задняя дверь») — дефект алгоритма, который намеренно встраивается в него разработчиком и позволяет получить несанкционированный доступ к данным или удалённому управлению операционной системой и компьютером в целом.

Также в результатах nikto отображает код OSVDB 561 и дает ссылку на CVE-2003-1418. OSVDB — это аббревиатура базы данных уязвимостей с открытым исходным кодом.

CVE-2003-1418 — это уязвимость в Apache HTTP Server 1.3.22–1.3.27 на OpenBSD, которая позволяет удалённым злоумышленникам получать конфиденциальную информацию через:

- Заголовок ETag, который раскрывает номер vode.
- Многочастную границу MIME, которая раскрывает идентификаторы дочерних процессов (PID).

В настоящее время эта проблема имеет среднюю степень тяжести.

## 5 Выводы

В ходе работы я научилась использовать сканер nikto для тестирования веб-приложений.